

Relatório de Projeto Prático: Simulação de Força Bruta

Riachuelo - Cibersegurança — Plataforma DIO

Por: Adryel Batista de Sena

1. Visão Geral do projeto

Este documento consolida a execução do laboratório prático focado em simulações de ataques de força bruta, auditoria de segurança de serviços de rede e estruturação de medidas de mitigação utilizando ferramentas de código aberto em ambiente controlado.

2. CONFIGURAÇÃO DO LABORATÓRIO

- Ambiente de Ataque: Kali Linux (IP: 192.168.56.101)
- Ambiente Alvo: Metasploitable 2 (IP: 192.168.56.102)
- Infraestrutura de Rede: Rede Interna isolada (Host-Only no VirtualBox)

3. Criando arquivos de Usuários e Senhas comuns

A. Utilização de ferramentas

Nessa etapa, serão criados dois documentos para invasão de invasão para testes utilizando a ferramenta “Medusa” no Kali Linux:

Para que a ferramenta consiga fazer testes automatizados, precisamos estruturar dois arquivos fundamentais no diretório de trabalho do Kali Linux: um contendo os nomes de usuários potenciais e outro com as senhas mais comuns a serem testadas.

1. Criação de arquivo de lista de usuários:

Para isso, é necessário abrir o terminal do Kali Linux e digitar o comando: `echo -e`

```
"user\nadmin\nmsfadmin\nroot" > users.txt
```

2. Criação de arquivo de lista de senhas:

Seguindo a mesma lógica da criação de lista de usuários, será utilizado: `echo -e`

`"123456\npassword\nqwerty\nmsfadmin" > pass.txt`

Ao seguir esses passos, os dois arquivos serão criados e guardados nos arquivos Kali para serem usados no ataque de força bruta. Para usar as listas de forma automatizada utilizando o Medusa o seguinte comando é usado: `medusa -h 192.168.56.102 -U users.txt -P pass.txt -M ftp -t 6` dessa forma o protocolo FTP é diretamente atacado, utilizando as listas e o ip do alvo.

B. Reflexão sobre o ataque

Ao estudar como o ataque de força bruta funciona, fica evidente a importancia de se proteger e prevenir-se de dados confidenciais vazados, com algumas informações vazadas, alguém mal intencionado pode realizar o ataque estudado e acabar por tomar controle de plataformas de uso pessoal, podendo se beneficiar de forma prejudicial ao usuário.

4. Entendendo como a rede de navegação funciona

A. Utilizando site vulnerável

Para melhor entendimento de como as informações viajam na internet, utilizaremos um site vulnerável chamado "DVWA" criado para estudos de cibersegurança, onde informações de login e senha são requeridas para o usuário.

1. Acesso de formulário:

Para acessar o site, abriremos o navegador e pesquisamos por:

`http://192.168.56.102/dvwa/login.php` O ip para acesso pode ser diferente ao depender do alvo, neste caso é usado o ip do ambiente alvo, já visto no começo do relatório: `192.168.56.102`

2. Visualização dos dados enviados para o servidor:

Ao acessar o site, e abrindo a barra de desenvolvedor apertando a tecla F12 e selecionando a opção "Network", será possível ver todas as informações enviadas e recebidas pelo servidor. Ao colocar um login e senha qualquer, o servidor gera arquivos de dados que podem ser visualizados ao selecionar o documento do tipo "Post" e selecionando a opção "Request" ao lado direito, dessa forma, podemos ver a tentativa de acesso com o login e senha utilizados.

B. Invasão com força bruta

Como já visto no terceiro tópico, a ferramenta Medusa é usada para a invasão de sistemas, e neste caso não será diferente.

1. Código necessário:

`medusa -h 192.168.56.102 -U users.txt -P pass.txt -M http \`: Usa as wordlists com login e senhas comuns já criados anteriormente.

No comando do Medusa, o parâmetro `-O` (com 'O' maiúsculo) serve para passar opções específicas e avançadas para o módulo que você está utilizando (neste caso, o módulo `http`).

`-O URL:/dvwa/login.php \`: Define a URL do alvo.

`-O FORM:"username=^USER^&password=^PASS^&Login=Login" \`: Mapeia os campos do formulário HTML preenchendo dinamicamente o usuário, a senha e a ação de envio (botão de login).

`-O FAIL:"Login failed" -t 6`: Define a string de erro retornada pela página em caso de falha na autenticação e determina o uso de 6 threads simultâneas para otimizar a velocidade do teste.

De forma automatizada, conseguimos o acesso no servidor com a seguinte informações: **Usuário:** admin e **Senha:** password

5. Testando cenários corporativos mal protegidos

A. Ambientes mal configurados

Neste tópico, focamos em simulações contra o protocolo SMB, e nesse parágrafo utilizaremos password spraying para testar a resiliência das credenciais em múltiplos alvos simultaneamente. Alguns serviços de rede em ambientes corporativos mantêm configurações padrão de fábrica ou senhas simplificadas, facilitando o acesso não autorizado, o ataque será simulado novamente no Metasploitable 2.

1. Comando de ataque:

ao abrir o terminal do Kali Linux, usaremos: `enum4linux -a 192.168.56.102 | tee enum4_output.txt`

`enum4linux` É uma ferramenta de linha de comando desenvolvida em Perl, focada em enumerar informações de sistemas Windows e servidores Samba/SMB.

`-a` É o parâmetro de "varredura agressiva" (*all*). Ele diz para a ferramenta executar a maioria das opções de enumeração de uma só vez, o que inclui extrair lista de usuários, grupos, compartilhamentos de rede (*shares*), informações do sistema operacional, políticas de senha e mapeamento de IDs (RID cycling).

`192.168.56.102` É o endereço IP do alvo (neste caso, a máquina virtual Metasploitable 2) que será escaneado.

|(pipe): O operador pipe pega todo o texto gerado na tela pelo comando anterior (enum4linux) e o envia diretamente como entrada para o próximo comando.

tee enum4_output.txt O comando tee cumpre uma função dupla muito útil em relatórios técnicos: ele exibe a saída do comando na tela em tempo real e, ao mesmo tempo, salva todo o conteúdo em um arquivo de texto chamado enum4_output.txt no seu diretório atual.

Em seguida usamos **less output.txt** para ler o arquivo e encontrar informações sigilosas para ataques, como, nomes reais das contas do sistema remoto, em outros cenários, vários tipos de informações confidenciais.

B. Utilização de dados encontrados

Ao invadir e fazer uma varredura por todo histórico do sistema com usuários, senhas e dentre outros tipos de informações, fica mais fácil fazer testes de invasão com dados tão certos.

1. Criando lista de login:

Como já visto neste documento, criaremos lista de login e senhas para tentativa de acesso no sistema.

Lista de possíveis usuários:

```
echo -e "user\nmsfadmin\nnsservice" > smb_users.txt
```

Lista de possíveis senhas:

```
echo -e "password\n123456\nnnWelcome123\nmsfadmin" > senhas_spray.txt
```

Comando para iniciar os testes de invasão:

```
medusa -h 192.168.56.102 -U smb_users.txt -P senhas_spray.txt -M smbnt -t 2 -T 50
```

Duas novas flags aparecem nesse caso, sendo eles:

-M smbnt: Módulo específico para ataques SMB.

-t 2: Simula dois usuários testando senhas.

-T 50: Até 50 hosts em paralelo.

Dessa forma, obtemos as seguintes informações: Usuário: msfadmin e Senha: msfadmin. Ademais, tal usuário e senha são informadas como contendo acesso de administrador.

6. Testando acesso final

A. Último teste a máquina

Chegamos ao último tópico da oficina, onde confirmaremos se as informações do tópico 5 podem ser validadas corretamente usando a ferramenta Smbclient.

1. Uso da ferramenta:

Ao abrir a central de comando do Kali, será digitado: `smbclient -L //192.168.56.102 -U msfadmin`

Explicação das Flags e Parâmetros:

smbclient É uma ferramenta de linha de linha do Linux que funciona como um cliente para interagir com servidores e compartilhamentos de rede SMB/CIFS (permitindo listar pastas, baixar/enviar arquivos e testar credenciais).

-L A flag de listagem (*List*). Ela diz ao smbclient para consultar o servidor alvo e exibir todos os recursos disponíveis nele (como compartilhamentos de arquivos (*shares*), impressoras e grupos de trabalho), sem precisar se conectar diretamente a uma pasta específica.

//192.168.56.102 É o endereço IP do servidor alvo (a máquina Metasploitable 2) precedido por barras duplas, que é o formato padrão exigido pelo protocolo SMB para indicar o host remoto.

-U msfadmin A flag de usuário (*User*). Informa qual nome de conta será utilizado para autenticar a conexão com o servidor (neste caso, o usuário msfadmin descoberto anteriormente). Logo após executar o comando, o terminal pedirá que você digite a senha correspondente.

2. Reflexão final sobre oficina:

Para garantir uma camada básica e eficiente de segurança contra acessos não autorizados e ataques como os que testamos no laboratório, é fundamental adotar práticas essenciais no dia a dia:

Senhas Fortes: Utilize combinações longas que misturem letras maiúsculas, minúsculas, números e caracteres especiais, evitando totalmente termos óbvios, sequências numéricas ou dados pessoais.

Autenticação de Dois Fatores (2FA): Ative essa camada extra sempre que possível; ela exige uma segunda forma de confirmação (como um código em aplicativo authenticator) além da senha.

Princípio do Menos Privilégio: Conceda aos usuários e sistemas apenas as permissões estritamente necessárias para realizar suas funções, reduzindo o impacto em caso de brechas.

Atualizações Constantes: Mantenha softwares, sistemas operacionais e protocolos sempre atualizados para corrigir vulnerabilidades conhecidas exploradas por invasores.
